

UC11 • LABORATÓRIO DE REDES

Ataque, firewall e detecção — no mesmo laboratório

Kali, Metasploitable2, pfSense e Security Onion, ligados de verdade

Máquinas da sala: 16 GB RAM

Kali já instalado

O que vamos montar hoje

- 01 As 4 peças: atacante, alvo, firewall e SOC
- 02 A fiação de rede — a parte que quase todo mundo erra
- 03 Montar Metasploitable2, pfSense e Security Onion
- 04 O teste: atacar e ver o alerta aparecer
- 05 O que separa esse laboratório de mais um print no GitHub

O ponto de partida de vocês já está na frente

Já está pronto

VirtualBox instalado, **16 GB de RAM** por máquina, placa de vídeo boa e o **Kali Linux já rodando** — a parte mais chata para quem monta isso em casa.

O que falta montar

Três máquinas virtuais: o **alvo** (Metasploitable2), o **firewall** (pfSense) e o **SOC** (Security Onion) — e ligar tudo do jeito certo.

Um atacante, um alvo cheio de falhas, um firewall no meio e um SOC vigiando o cabo — é a rede mais parecida com uma de verdade que dá para montar sem ter um emprego, e não custa nada.

BLOCO 01

As 4 peças do laboratório

Cinco downloads, todos gratuitos

0 alvo

Metasploitable2 — quebrado de propósito

A Rapid7 construiu essa VM para ter falhas. Não é bug, é **recurso**. Um museu de jeitos de ser hackeado, todos abertos.

Porta	O problema
21	vsftpd 2.3.4 com um backdoor plantado direto no código-fonte
6667	servidor IRC com outro backdoor
1524	entrega um shell de root sem pedir senha nenhuma

Login: msfadmin / msfadmin · 512 MB de RAM já é suficiente

0 firewall

pfSense — um roteador de verdade, de graça

pfSense CE é um firewall e roteador completo da Netgate, versão Community, sem custo.

1 GB de RAM, **duas placas de rede** — e essa segunda placa é o ponto inteiro do exercício.

Adapter 1 — WAN

NAT

Adapter 2 — LAN

Internal Network "lab"

0 SOC

Security Onion — o que um analista fica olhando o dia todo

Suricata, Zeek e um stack Elastic, tudo numa VM só. Instala em modo **EVAL** — o modo "máquina única", feito exatamente para isso.

RAM

8 GB

CPUs

4

Disco

~200 GB

É a VM mais pesada das quatro — e é exatamente por isso que estamos fazendo na sala, com máquinas de 16 GB, e não em casa.

BLOCO 02

A parte que todo mundo erra

A fiação de rede entre as quatro VMs

Toda placa de rede da VM tem um modo

NAT

A VM sai para a internet através do seu computador.

Bridged

A VM se comporta como um aparelho físico dentro da **rede real** — no caso, a rede da escola.

Internal Network

A VM só fala com outras VMs que estejam na **mesma rede interna nomeada**. Nada de fora do computador consegue ver isso.

A REGRA

O Metasploitable nunca encosta em NAT ou Bridged. Nunca.

Ele tem um shell de root numa porta aberta, sem senha nenhuma. Colocar isso em Bridged é colocar esse shell aberto direto na rede Wi-Fi da escola.

Só Internal Network. Sempre.

O mapa completo da rede

Kali

1 placa

Internal "lab"

Metasploitable

1 placa

Internal "lab"

pfSense

Adapter 1: NAT (WAN)

Adapter 2: Internal "lab" (LAN)

Security Onion

Adapter 1: NAT (gestão)

Adapter 2: Internal "lab", sem IP

Promiscuous Mode: Allow All

Kali e Metasploitable ficam na mesma rede privada, com o pfSense como gateway. Security Onion enxerga tudo que passa por ali porque a segunda placa está em modo promíscuo — **o checkbox que mais gente esquece.**

Montando o Metasploitable2

- 1 Baixe em sourceforge.net/projects/metasploitable e extraia o zip. Dentro está o **Metasploitable.vmdk**.
- 2 No VirtualBox: New → nome "Metasploitable", tipo Linux, versão Ubuntu (32-bit).
- 3 512 MB de RAM. Em "hard disk", escolha "**Use an existing virtual hard disk file**" e aponte para o .vmdk.
- 4 Settings → Network → Adapter 1: **Internal Network**, nome "**lab**".
- 5 Ligue, login **msfadmin** / **msfadmin**, rode ifconfig e anote o IP.

Montando o pfSense

- 1 pfsense.org/download → Community Edition, AMD64. Pode pedir uma conta grátis na Netgate — o software continua gratuito.
- 2 New VM: nome "pfSense", tipo BSD, versão FreeBSD (64-bit), 1024 MB RAM, disco novo de 8 GB.
- 3 Settings → Storage: prenda o ISO do instalador na unidade óptica.
- 4 Settings → Network: Adapter 1 = **NAT**. Aba Adapter 2: Enable, **Internal Network "lab"**.
- 5 Instale com as opções padrão do instalador. Ao reiniciar, atribua WAN = primeira placa, LAN = segunda placa.
- 6 Reinicie Kali e Metasploitable para pegarem IP por DHCP do pfSense.

Montando o Security Onion

- 1 github.com/Security-Onion-Solutions/securityonion, branch 2.4 → siga o link do DOWNLOAD_AND_VERIFY_ISO.md até o ISO.
- 2 New VM: nome "SecurityOnion", tipo Linux, versão Oracle Linux (64-bit). 8192 MB RAM, 4 processadores, disco novo de 200 GB dinâmico.
- 3 Settings → Storage: prenda o ISO. Settings → Network: Adapter 1 = **NAT**; aba Adapter 2: Enable, **Internal Network "lab"**.
- 4 Clique em **Advanced** no Adapter 2 e mude **Promiscuous Mode** para **"Allow All"**. É o checkbox que quase todo mundo esquece.
- 5 Boot → Install → tipo de instalação **EVAL** → primeira placa como gestão, segunda como interface de monitoramento.
- 6 Deixe rodar (demora). No final, ele mostra um endereço web — abra no navegador do host, faça login e clique em **Alerts**.

O teste

No Kali

No Security Onion
Atualize a tela **Alerts**

Assinaturas do Suricata devem aparecer, com o IP do Kali como origem.

Você atacou algo, um firewall ficou no meio do caminho e um sistema de detecção viu. É esse ciclo que sustenta qualquer trabalho de blue team.

Alerts vazio? É quase sempre o promiscuous mode. Volte no passo 4 da montagem do Security Onion.

BLOCO 03

O que separa isso de mais um print no GitHub

Montar o laboratório é a entrada. Não é o diferencial.

O caminho mais comum

Alguém monta esse laboratório, roda o nmap, vê o alerta do Suricata, tira um print, escreve um README chamado "Home Lab Project" com uma lista de cinco ferramentas, sobe pro GitHub e coloca no currículo: "montei um lab com Kali, pfSense e Security Onion".

Depois, nada acontece.

Porque fez o mínimo. E todo mundo fez o mínimo. Um recrutador já viu esse README uma centena de vezes — metade escrita por um chatbot.

1 Documento de verdade

Não é um README com lista de bullets. É um relato real: o que você esperava que o firewall fizesse, versus o que ele realmente fez.

A regra exata do Suricata que disparou — com o ID da regra — e o que ela está procurando.

O momento em que ficou 40 minutos sem nenhum tráfego porque esqueceu o promiscuous mode — e como descobriu.

Os erros de percurso são a parte mais valiosa: ninguém mais escreve isso, e é isso que prova que foi um humano que fez.

2

Vá além do guia

Escreva uma regra própria do Suricata que pegue algo que a regra padrão não pega.

Crie uma regra no pfSense que bloqueie o scan — e prove com um antes e depois.

Escreva um script Python de dez linhas que roda o scan e puxa a contagem de alertas da API do Security Onion.

Coloque cada um desses no repositório.

3

Grave a tela e mostre

Grave o processo inteiro, incluindo as partes em que não funcionou. Narre o que está fazendo. Publique.

Ninguém vai encontrar seu GitHub. Mas um vídeo de três minutos de uma pessoa explicando por que o IDS não disparou, e depois consertando isso, é algo que um recrutador assiste no celular.

LinkedIn, YouTube, formato curto — o canal importa menos do que existir.

4 Fale com uma pessoa real

Ache uma pessoa que trabalha num SOC de verdade — LinkedIn, Discord, um evento, amigo de amigo.

Mande o vídeo e uma pergunta: **"o que você teria feito diferente?"**

A maioria não vai responder. Uma vai. E essa conversa vale mais que os próximos três laboratórios juntos.

Recap

- ✓ Kali (já instalado) + Metasploitable2 + pfSense + Security Onion
- ✓ Metasploitable e Kali em Internal Network "lab" — nunca NAT/Bridged no Metasploitable
- ✓ pfSense com uma perna NAT e outra na "lab"
- ✓ Security Onion com promiscuous mode "Allow All" na segunda placa
- ✓ nmap do Kali aparecendo como alerta no Security Onion

Ressalva honesta: o Metasploitable2 é de 2012. As falhas são antigas. Serve para entender como exploração funciona na prática — não mostra como é uma máquina moderna e corrigida. Está tudo bem para um primeiro laboratório. Só saiba o que é.

Documentar, ir além, gravar, conversar — é isso que vira diferencial.